

Banco Santander International

Technology



Privileged Access Management Recertification Procedure

DOCUMENT HISTORY AND VERSION CONTROL

Ownership and Authorship

Version	Date	Author	Owner	Change
1.0	April 22, 2025	Santander US Head of Identity and Access Services	Banco Santander International ("BSI") Chief Information Security Officer ("CISO")	Initial Version – Consolidation of Privileged Access Management Recertification Procedure and CyberArk Privilege Access Management Recertification Procedure
2.0	04/22/2026	Santander US Head of Identity and Access Services	Banco Santander International ("BSI") Chief Information Security Officer ("CISO")	Annual Review: Material Changes, Updated RCSA process Maps and Control language, Added RASCI Chart

Sign Off

Approver /Reviewer	Action	Date
Technology Policy Administration Team	Document Review	04/22/2026
BSI CISO	Approval	04/22/2026

TABLE OF CONTENTS

DOCUMENT HISTORY AND VERSION CONTROL..... 2

OWNERSHIP AND AUTHORSHIP.....2

SIGN OFF.....2

1 INTRODUCTION 4

1.1 PURPOSE OF THIS DOCUMENT4

1.2 SCOPE4

1.3 OUT OF SCOPE.....4

2 PROCEDURE REQUIREMENT 4

3 ROLES & RESPONSIBILITIES..... 5

4 CONTROL AND MONITORING 6

4.1 CONTROLS6

4.1.1 Beneficiary’s Line Manager & Owner Recertification.....6

4.1.2 LDAP CyberArk Group Owner Recertification6

4.1.3 Key Controls (MS SQL, Oracle, , Windows server, Active Directory, Unix / Linux, , CyberArk).....7

4.2 MONITORING7

5 REPORTING AND ESCALATION/EXCEPTIONS 7

6 GOVERNANCE/OVERSIGHT 7

7 RELATED DOCUMENTS..... 8

8 PROCEDURE 9

9 RASCI CHART..... 12

10 QUESTIONS/CONTACT INFORMATION 13

11 APPENDIX..... 13

11.1 GLOSSARY13

1 INTRODUCTION

1.1 Purpose of this Document

The Privileged Access Management (“PAM”) Recertification Procedure (this “Procedure”) provides a procedure that will be adhered to by all work force members regarding privileged access recertification, including access review and approval/revocation. This Procedure is applicable for all Technology standard users (workforce members) and nonstandard users (contractors, contingent workers).

1.2 Scope

This Procedure is applicable to Banco Santander International (“BSI”) or collectively (“Bank”). It applies to all groups managing Santander IT Systems, as well as to all information assets with existing privileged accounts.

1.3 Out of Scope

This Procedure is not applicable to systems that are not managed by or on behalf of Combined US Operations of Banco Santander, S.A. (“CUSO) and Banco Santander International.

2 PROCEDURE REQUIREMENT

This Procedure must be followed for all privileged access recertifications.

For SOX, this includes quarterly recertification by the line manager for Person ID entitlements and by the owner for service ID entitlements.

For GLBA, this includes semi-annual recertification by the line manager for Person ID entitlements and by the owner for service ID entitlements. For CyberArk, this includes quarterly recertification by the line manager for Person ID entitlements, by the owner for service ID entitlements, and by the Lightweight Directory Access Protocol (“LDAP”) CyberArk Group Owner for Person ID members.

This Procedure is to comply with Sarbanes-Oxley (“SOX”), and Gramm-Leach-Bliley Act (“GLBA”) requirements.

3 ROLES & RESPONSIBILITIES

Role/Function	Role / Function Description	Organizational Accountability
Beneficiary Line Manager	The beneficiary line manager is responsible for: Reviewing the privileged access of their direct reports and either approve or rejecting their privileged access.	Business Line
IT Application Support	IT Application Support is responsible for the provisioning and de-provisioning of new, existing, and terminated employees/contractors' access to systems.	IT Services and Delivery
PAM US Team	The PAM US Team is responsible for: - Initiating the SOX user recertification process quarterly - Initiating the GLBA user recertification process semi-annually. - Initiating the Corporate LDAP CyberArk Group recertification process quarterly. - Initiates other recertifications (as required) - Submitting ServiceNow requests revocation in the event of a recertification rejection or non-response. - Reviewing all changes are made in accordance with the recertification decision. - Collecting and storing approval and rejecting evidence. - Collecting and storing evidence of revocation. - Identifying assets and platforms in-scope for PAM access recertification - Running entitlement scripts and reviews scripts results.	Information Security
Santander Identity Access Management ("SanIAM")	The SanIAM team is responsible for: - Overseeing recertification activities. - Performing access recertifications reviews (manager approval/revocation). - Stages user certifications and retains certification decisions. - Generates work items for user access revocation in the event of a certification rejection directed to the PAM team.	Information Security

4 CONTROL AND MONITORING

4.1 Controls

The management controls described below support the defined process and must be performed to ensure that the process is executed as designed.

No.	Control
C1	The population for recertification is reviewed and confirmed.
C2	Managers review and Approve/Revoke Access
C3	IT Application Support will revoke access as requested

4.1.1 Beneficiary's Line Manager & Owner Recertification

No.	Control
C1	The PAM team initiates a manager privilege user access certification (for person accounts) & owner certification (for non-person accounts) via SanIAM.
C2	The Beneficiary's line manager or non-person account owner reviews and approves/rejects the users' access within SanIAM.
C3	In the event of a beneficiary's manager or non-person account owner rejection for Access, the PAM Team submits a ServiceNow Access Revocation ticket to the IT Application Support team.
C4	When the ServiceNow ticket is closed, the PAM Team confirms that access is de-provisioned correctly.

4.1.2 LDAP CyberArk Group Owner Recertification

No.	Control
C1	The PAM team initiates an LDAP CyberArk Group Owner privilege user access certification.
C2	The LDAP CyberArk Group Owner reviews and approves/rejects the users' access.
C3	In the event of a LDAP CyberArk Group Owner rejection for Access, the PAM Team submits a ServiceNow Access Revocation ticket to the IT Application Support team.
C4	When the ServiceNow ticket is closed, the PAM Team confirms that access is de-provisioned correctly.

4.1.3 Key Controls (MS SQL, Oracle, , Windows server, Active Directory, Unix / Linux, , CyberArk)

The management controls described below support the defined process and will be done to confirm that the Procedure is executed as designed.

No.	Control
C1	Review scripts to confirm validity and confirm completion of server & database list.
C2	Confirm all server & database outputs are complete, or database is documented as out of production
C3	Confirm completeness of privileged access list
C4	Confirm accuracy and completeness of prepared data

4.2 Monitoring

Adherence is monitored by Internal Control, and any findings will be reported to Senior and Executive Management. If PAM US Team identifies that a user whose access was rejected during a quarterly certification but maintained their privileges this finding will be escalated to senior management if the issue is not remediated.

Findings from the review of the above controls will be reported monthly to the Santander US Head of Identity and Access Services and BSI CISO.

5 REPORTING AND ESCALATION/EXCEPTIONS

Exceptions to this procedure will be reviewed on a case-by-case basis by the Santander US Head of Identity and Access Services and approved by the BSI CISO.

Key Risk Indicator ("KRI") is included in the monthly Operational Risk Management Dashboard which is presented to InfoSec Steering Committee and GLBA Steering Committee.

6 GOVERNANCE/OVERSIGHT

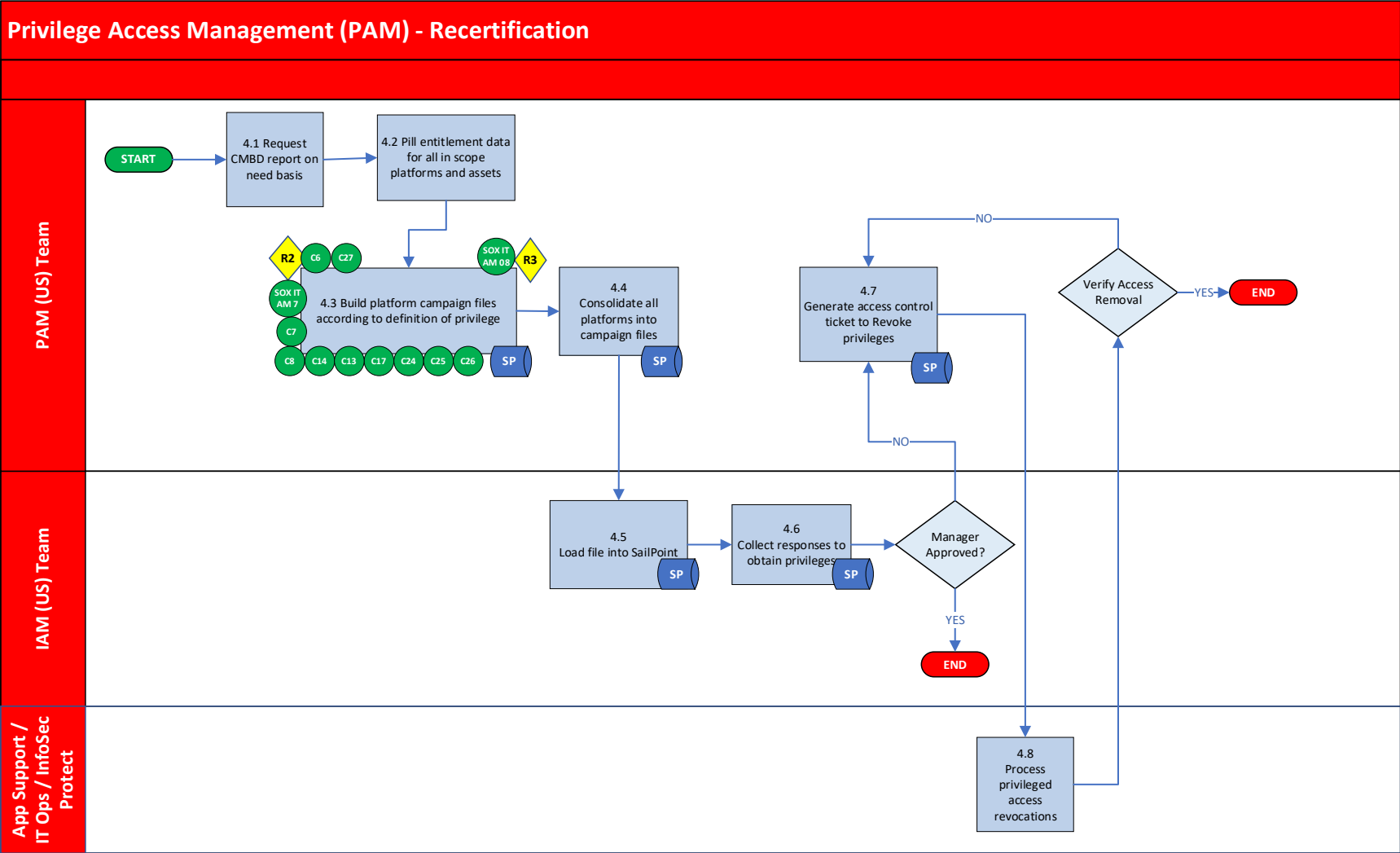
This Procedure is authored by the Santander US Head of Identity and Access Services and approved by the BSI CISO.

This Procedure is reviewed annually or when a material change to the operating environment, potential changes to regulations and contractual requirements, potential findings, or requested policies exceptions necessitate an out of cycle review.

7 RELATED DOCUMENTS

Document Type	Entity and Department	Owner	Document Title
Enterprise	Risk	Santander US, Chief Risk Officer ("CRO")	CUSO Information Risk Management Policy
Standard	Risk	Santander US, Chief Risk Officer ("CRO")	CUSO Assurance Management – Policy and Standards & Compliance Management Standard
Standard	Technology	Santander US, Head of US Infrastructure Operations	CUSO Asset Management Standard
Standard	Technology	Santander US, Chief Information Security Officer ("CISO")	CUSO Authentication and Authorization Standard
Standard	Technology	Santander US, Chief Information Security Officer ("CISO")	CUSO Identity and Access Management Standard
Technical Standard	Technology	T&O Chief Operating Officer ("COO")	CUSO Application Portfolio Management Technical Standard

8 PROCEDURE



Step	Action
1	PAM team determines scope of certification, either through AMR extract provided by Asset Management team or other known source data (i.e., CMDB) approved by PAM management.
2	PAM team collects entitlement data from in-scope systems.
3	PAM team performs necessary platform-specific manipulations to extract only privileged access entitlements.
4	PAM team assigns all entitlements to campaign decision makers; either automatically by line manager according to HR (for person entitlements) or to appropriate accounts, groups, or application/platform owners (for non-person entitlements).
5	PAM team consolidates all in scope certification access entitlements and formats the data for upload to SANIAM system.
6	IAM team loads certification provided by PAM team to SANIAM and provides PAM team with a certification review report.
7	PAM team requests launch of certification by loading the file into SailPoint
8	The IAM team notifies campaign decision makers of assignments and tracks completion throughout certification. Additionally, the IAM team collect responses from decision makers.
9	When all assignees have completed their decisions, if the manager approves the user access, the process ends. If access is revoked, the PAM team submits revocation tickets for any "reject" decision or terminated users.
10	PAM team verifies completion of all revocations.

8.1 Recertification Controls

Risk/Control	Description
C6	Quarterly, the Information Security/PAM/IAM/SDS teams manage documented access reviews of privileged access to productions databases.
C7	At least semiannually, InfoSec initiates accounts reviews for network device administrators, users and service accounts that will be performed by managers or account owners.
C8	Quarterly, the Chief Information Security Officer (CISO) reviews and approves the privileged access management (PAM) application (CyberArk) administrators and identifies users for access revocation.
C13	At least semi-annually the PAM team performs a recertification of LDAP groups mapping to safes. Group owners identify safes for which access should be approved or revoked.
C14	At least semi-annually, a recertification of Privileged Users access is completed by the Infrastructure Management/Information Security tool owner by reviewing who has admin access to the specific tool.
C17	On semi-annual basis, Information Security/PAM/IAM/SDS teams manage documented accounts of privileged access of production OS systems
C24	Access] On a quarterly basis, the Information Security/PAM/IAM team manages documented access reviews for users in CyberArk LDAP groups.
C25	At least semi-annually, the Information Security/PAM/IAM team manages documented, manual access reviews for group members of PAM SOX Active Directory groups that permit access to infrastructure.
C26	Semi-Annually, the Information Security/PAM/IAM/SDS teams manage documented access reviews of privileged access to productions databases.
C27	On Quarterly basis, Information Security/PAM/IAM/SDS teams manage documented accounts of privileged access of production OS systems.
SOX IT AM 07	On a quarterly basis, privileged access to databases and operating systems are reviewed for users (by their managers) and service accounts (by owners) to ensure that access is appropriately restricted based on job responsibilities.
SOX IT AM 08	On a quarterly basis, users with access to CyberArk vaults related to SOX in-scope applications are reviewed by the LDAP Group owners to ensure that access is appropriately restricted based on job responsibilities.
R2	Access Review. Inappropriate user access to systems and/or data due to a failure to perform privileged access reviews may result in disruption of business processes, financial loss and regulatory noncompliance.
R3	Priv Mgt. Inappropriate privileged user access to systems and/or data due to a failure to manage privilege accounts with an access management tool / system, may result in disruption of business processes, financial loss and regulatory noncompliance.

9 RASCI CHART

Instructions:	RASCI Value Legend:
1) Replace Roles with actual Role names.	R = Responsible
2) Replace Tasks with actual Task names.	A = Accountable
3) Assign RASCI Value by Task/Role in matrix.	S = Support
	C = Consulted
Note: More than one value may occupy a cell.	I = Informed

Tasks	Roles					
	PAM US Team	SanIAM (IAM Team)	Line Manager	Account / Group Owner Manager	IT Application Support	BSI CISO
1. Define Scope & Population for Recertification	R	S	I	C	I	A
2. Collect & Prepare Privileged Access Data (Entitlements, Scripts, Validation)	R	S	I	I	C	A
3. Load & Configure Certification Campaign (SanIAM / SailPoint)	S	R	I	I	I	A
4. Execute Access Review (Approve / Revoke Decisions)	S	R/S	R	R	I	A
5. Track Certification Completion & Collect Evidence	R	R	S	I	I	A
6. Initiate & Process Access Revocation (ServiceNow Tickets)	R	S	I	I	R	A
7. Validate Revocation Completion & Closure	R	R	I	I	R	A
8. Control Execution & Quality Assurance (Completeness, Accuracy, Key Controls)	R	S	I	I	C	A
9. Monitoring, Reporting & Escalation (KRI, Exceptions, Issues)	R	S	I	I	I	A
10. Governance Oversight & Procedure Approval	S	I	I	I	I	A

10 QUESTIONS/CONTACT INFORMATION

Function	Contact
Santander US Head of Identity and Access Services	Robert Burden (robert.burden@santander.us)
Santander US Director, PAM	James Lucas (james.lucas@santander.us)
BSI Chief Information Security Officer	Dayam Borges <dborges@bpi-gruposantander.com>

11 APPENDIX

11.1 Glossary

Term	Description
Access Management (US)	US Access Management Team
CIO	Chief Information Officer
IAM	Identity Access Management
IT	Information Technology
OU	Organization Unit within a Microsoft active directory
SanIAM	SailPoint IAM Platform for SHUSA